Global Skills Kenya (GSK)

Requirements Baseline v2.0 — End-to-End Workflows and Implementation Tasks 1–8

Version 2.0 | 13 October 2026 | Requirements baseline and AI-developer handoff

DECISION PRINCIPLE

Make safe, reversible decisions in the specification. Do not fabricate legal approvals, provider selections, staffing coverage, or production readiness.

Document status and rules

Status

Working requirements baseline for consultant review and AI-developer handoff. It consolidates decisions that can be made safely now; it is not a legal opinion, provider contract, staffing commitment, or proof of production readiness.

Source of truth

This document supplements the Consultant Decision Report v1 and Roles & Permissions Specification v1. If wording conflicts, apply this order: (1) explicit user-approved decision, (2) this v2 baseline, (3) role specification, (4) prior scaffold comments. The developer must raise conflicts instead of silently choosing.

Decision labels

BASELINE = proceed with this rule unless a genuine blocker emerges. CONFIRM BEFORE LAUNCH = a named human owner, legal reviewer, provider, or operational decision must confirm it. DEFERRED = excluded from MVP unless approved through change control.

Operating model

Hybrid. GSK centrally owns platform governance, canonical records, policy, verification decisions, approvals, audit, and safeguarding oversight. Approved partners perform assigned programme activities only within scoped records and documented agreements. No partner-wide browsing.

Product boundary

Responsive web application; Laravel with relational database; accessible, mobile-first UI. MVP includes public information, candidate profiles, employers, vacancies/applications, placement tracking, welfare reporting/case management, one-time donations, CMS, notifications, consent/data-sharing controls, reporting, and audit. Native mobile apps and broad integrations are not MVP requirements.

No fabricated completeness

The requirements can be baselined now, but launch is blocked until the specific operational/legal/provider items listed in the final open-decision register are resolved. The developer may build safe foundations and test fixtures before those approvals, but must not activate unresolved production behaviour.

Global product and engineering rules

Security

Default deny; enforce authorization on the server for every request, API, export, download, background job, and state transition. UI hiding is not authorization. Apply both role permissions and record/programme/country scope.

Identity

Email verification required for self-service candidate accounts. Staff accounts are invitation-only, require MFA, and are disabled promptly on exit. Employer representatives must verify email and be associated with a verified employer before publishing or accessing employer-restricted functions.

Data classification

Public; internal; confidential personal; sensitive personal/welfare; financial; security/audit. Sensitive/welfare content must not appear in ordinary email/SMS/WhatsApp, push notifications, analytics, or logs. Send a neutral notification and require authenticated access.

Audit

Append-only audit events for sign-in/security events, role and scope changes, record reads where sensitive, exports, consent changes, verification/approval decisions, state transitions, payments/refunds, file access, break-glass, and deletion/retention actions. Record actor, timestamp, object, action, result, reason where applicable, correlation ID, and relevant before/after fields without copying unnecessary sensitive payloads.

Uploads

Private storage outside the public webroot; allowlisted MIME/type and size checks; generated storage names; malware scanning where available; authorization on every download; short-lived signed URLs only if needed; no direct public paths. Never trust filename or client MIME type.

Reliability

Use database transactions for multi-record business actions; idempotency keys for provider callbacks and payment/refund commands; retries for transient notification/queue failures; dead-letter/review path; alert on stuck critical jobs. Do not claim delivery merely because a message was queued.

Accessibility

Target WCAG 2.2 AA, keyboard support, visible focus, labels/errors, sufficient contrast, meaningful headings, accessible authentication, and mobile usability.

Quality

Feature tests for positive and negative authorization, state transitions, duplicate submissions, replayed callbacks, expired links, retention, and cross-programme/cross-partner isolation. Tests must use synthetic data, not real beneficiary records.

Architecture

Keep policy/state-transition logic in application/domain services or equivalent testable components, not scattered only across controllers. Use explicit enums/state machines, database constraints, queue jobs for external side effects, structured logging with redaction, and versioned migrations.

Change control

Any new role, state, data field, integration, sharing purpose, or approval bypass requires a change request with rationale, risk, owner, migration impact, tests, and acceptance approval.

Workflow 1 — Candidate onboarding and profile

Actors

Candidate; programme officer; partner coordinator (scoped); recruitment officer (minimum necessary); privacy/data protection lead for rights requests.

States

Draft → Email-unverified → Active/incomplete → Submitted for review → Needs information / Verified / Restricted / Withdrawn / Deletion-pending. Verification is a workflow status, not a blanket claim that every fact/document is authentic.

Happy path

1) Candidate creates account and verifies email. 2) Candidate accepts versioned privacy notice and separately opts into optional communications. 3) Candidate completes minimum profile and selects programme interests/consents. 4) Candidate uploads only requested documents to private storage. 5) Submission creates a review task scoped to programme. 6) Officer reviews required fields/evidence and records decision plus reason. 7) Candidate sees status and missing items without seeing internal notes. 8) Approved profile becomes eligible for matching subject to each opportunity's criteria and consent.

Validation and safeguards

Collect minimum data at each stage; do not require passport/ID unless a documented programme/legal need exists. Candidate can save drafts and withdraw. Sensitive attributes are not used for automated ranking without approved lawful basis and fairness review. Never expose profile to an employer before a candidate applies or explicitly consents to a defined referral.

Exceptions

Duplicate account: flag for human review; do not merge automatically. Suspected forged document: restrict affected verification claim and escalate, not delete evidence without policy. Missing data: return to candidate with clear reason. Account compromise: suspend sessions, require recovery, audit. Candidate under 18: MVP default is not to onboard minors into international recruitment; if youth programmes include minors, a separately approved child safeguarding and guardian-consent flow is a launch blocker.

Acceptance tests

Unverified accounts cannot apply; draft profile is private; programme officer cannot access another programme without scope; employer cannot search/browse all candidates; document downloads are authorized and audited; consent versions are preserved; candidate can correct data and request rights handling; no sensitive document URL is public.

Workflow 2 — Employer and representative verification

States

Draft → Submitted → Under review → More evidence required / Approved / Rejected / Suspended / Expired.

Happy path

Employer creates organisation record and nominates representatives. Submit legal entity name, registration jurisdiction/number, business address, official contact, responsible contact, and evidence required by the approved checklist. Verifier independently checks evidence and records source/date/outcome. A different authorized approver approves high-risk or exception cases. Only approved, active employers can submit vacancies for publication.

Baseline controls

A representative cannot verify their own employer. Partner staff cannot self-approve their own organisation. Store verification outcome and evidence metadata; restrict original documents. Verify status periodically and on trigger (ownership change, complaint, expiry, failed payment, adverse signal).

Exceptions

Unclear or unavailable registry: mark pending, request alternative evidence and record rationale; do not silently approve. Suspected fraud or exploitation: suspend publication and refer to safeguarding/legal review. Expired verification: block new vacancy publication; preserve existing applications while human review determines safe handling.

Acceptance tests

Unverified/suspended/expired employers cannot publish; reviewer and approver separation is enforced where required; every decision has actor/time/reason/evidence reference; employers cannot read other employers' applicants; suspension invalidates relevant publication actions.

Workflow 3 — Vacancy, application, selection and offer

Vacancy states

Draft → Submitted for review → Changes requested / Approved for publication → Published → Paused / Closed / Expired / Withdrawn.

Application states

Started → Submitted → Under review → Shortlisted / Not selected / Interviewing → Offer made → Offer accepted / Offer declined / Withdrawn / Closed.

Happy path

Employer drafts vacancy with role, location, employer, pay/range where applicable, contract type, eligibility, deadline, costs/fees (normally none charged to candidate by GSK), accommodation/conditions if relevant, and international status. Automated completeness checks run. Authorized recruitment officer checks quality, employer status, discrimination/fraud red flags, and candidate-charging claims. Publisher approves and publishes. Candidate applies and explicitly confirms profile/document sharing for this vacancy. Employer receives only application data needed for selection. Decisions and communications are recorded; offers and acceptance are captured; placement workflow begins only after eligibility and required documents/approvals.

Baseline controls

No pay-to-apply model. GSK must not imply a visa, job, or placement is guaranteed. Do not allow employers to download bulk candidate lists. Employer contact details and internal risk notes remain restricted. Vacancy edits affecting material terms trigger re-review. Candidate withdrawal stops future optional sharing, subject to legitimate records/legal holds.

Exceptions

Suspected scam: pause immediately, preserve evidence, notify internal owner, assess affected applicants, and record disposition. Late application: reject with reason unless a documented exception is approved. Employer changes salary/fees/location after publication: pause and re-approve. Complaints of discrimination/exploitation route to welfare/safeguarding.

Acceptance tests

Only approved employer vacancies publish; material edits reset approval; candidate consent is tied to vacancy and recipient; employer can access only their own vacancy/applications; status changes send neutral notices; rejected/withdrawn candidates are not exposed to other employers.

Workflow 4 — International placement and follow-up

States

Potential match → Candidate interested → Eligibility review → Employer offer verified → Documentation/visa readiness → Sharing approval → Pre-departure readiness → Placement active → Follow-up due → Completed / Cancelled / At-risk / Escalated.

Happy path

1) Create a proposed match from a specific vacancy/application. 2) Confirm candidate interest and eligibility. 3) Independently validate employer offer and material terms. 4) Create a country-specific checklist for work authorization, travel, safeguarding, insurance/health requirements if relevant, and contact arrangements. 5) Determine required data recipients and obtain documented consent/legal basis. 6) Complete sharing approval before any cross-border disclosure. 7) Record pre-departure briefing, emergency contacts, complaint routes, and candidate acknowledgement. 8) Activate placement only after mandatory gates pass. 9) Schedule follow-ups and record welfare check-ins. 10) Close only after outcome and outstanding risks are reviewed.

Baseline controls

No automatic placement approval. A missing visa/work authorization or unresolved credible exploitation concern blocks activation. Do not collect or retain copies of documents without defined purpose and access restrictions. Track destination country, employer legal entity, recipient, purpose, data categories, transfer mechanism/legal basis, consent version, approvers, expiry/review date, and revocation.

Exceptions

Candidate declines: close match without penalty. Offer withdrawn: notify candidate, stop unnecessary sharing, reopen matching only with consent. At-risk placement: create welfare case and restrict access; do not notify employer about a report without safeguarding approval. Destination country or employer changes: repeat relevant eligibility, sharing and approval checks.

Acceptance tests

Placement cannot activate with incomplete mandatory checklist; cross-border share fails closed absent approved sharing record; change of country/recipient invalidates previous approval where scope differs; follow-up reminders are queued and auditable; welfare concerns are not visible to employer.

Workflow 5 — Welfare reporting and case management

Entry channels

Authenticated candidate/staff report and anonymous public report. Anonymous reporting does not require name, email, or account.

Severity

P1 imminent danger; P2 urgent risk; P3 standard welfare concern; P4 general support. Proposed internal acknowledgement targets during published staffed hours: P1 15 minutes; P2 1 hour; P3 1 business day; P4 3 business days. These are not public guarantees until staffed coverage and backup rota are signed off. No 24/7 promise without real coverage.

States

Received → Triage pending → Assigned → In progress → Waiting for reporter / referral / follow-up → Resolved pending review → Closed. Reopen on new information or failed safety plan. P1/P2 escalation may occur in parallel with normal states.

Happy path

1) Collect only report details needed for safe triage. 2) For anonymous reports, generate a high-entropy follow-up credential and display it once; store only a secure hash. 3) Triage by trained staff, assign severity and risk rationale. 4) Assign primary and backup owner. 5) Create safety actions, referral and follow-up dates. 6) Restrict case to safeguarding/welfare staff with need-to-know access. 7) Escalate severe risk via configured human contacts. 8) Review closure and preserve records per approved retention schedule.

Baseline controls

No recoverable anonymous credential; no sensitive case details in email/SMS. Access and downloads are audited. Case notes distinguish fact, allegation, assessment and action. Reporter-facing status reveals minimal information. A person implicated in a report must not access or approve that case. Staff must not promise confidentiality where law or immediate safety requires escalation; explain limits in plain language.

Exceptions

P1 with no contact details: follow internal emergency protocol and record actions possible; system must not imply responders can locate the reporter. Conflict-of-interest: reassign. Retaliation risk: suppress unsafe notifications and create safety plan. Anonymous credential lost: cannot recover; reporter must submit a new report and mention prior case if safe.

Acceptance tests

Anonymous report works without account; credential is shown once and cannot be retrieved from database/logs; P1/P2 create urgent tasks and escalate to configured recipients; only authorized welfare/safeguarding roles access case; case subjects cannot see reporter identity; closure and severity changes require reason and audit.

Workflow 6 — Donations, payment reconciliation and finance

States

Donation intent → Checkout initiated → Pending provider → Succeeded / Failed / Cancelled / Expired / Reversed / Refunded. Reconciliation status: Unmatched / Matched / Exception / Reconciled.

Happy path

1) Donor selects one-time donation, amount, currency and optional public/private acknowledgement preference. 2) Display accurate receipt/charity/tax wording approved by GSK. 3) Redirect to hosted provider checkout; GSK never handles raw card data. 4) Verify signed/authenticated callback or provider status server-to-server. 5) Process idempotently; update payment state only from verified provider evidence. 6) Issue receipt after confirmed success. 7) Reconcile provider settlements, fees, refunds and bank/M-Pesa settlement against internal ledger. 8) Finance officer reviews exceptions and exports approved reports.

Baseline decisions

One-time donations only for MVP. Recurring donations remain disabled until a chosen provider's mandate creation, cancellation, failed-payment, retry, notification, refund and reconciliation lifecycle has been contractually verified and tested. No raw card storage. Do not represent a donation as tax-deductible unless confirmed by legal/finance.

Refund controls

Proposed separation: finance officer requests; independent authorized approver approves refunds. Proposed approval threshold KES 20,000 equivalent; above that, second approver required. This is a configurable provisional threshold, not an accounting policy until finance owner approves. Never refund solely because a browser return URL says success.

Exceptions

Duplicate callback: idempotent no-op. Amount/currency mismatch: quarantine for review. Provider timeout: remain pending and query provider; do not mark failed prematurely. Chargeback/reversal: create exception and preserve linked audit. Refund provider failure: keep refund pending and alert finance.

Acceptance tests

No success state without verified provider evidence; webhook signatures and idempotency are tested; no secrets/card data in logs; receipt only after confirmed success; reconciliation identifies unmatched entries; recurring option is absent unless feature flag and provider readiness gate are approved.

Workflow 7 — Data-sharing and cross-border approval

States

Draft request → Privacy review → Safeguarding/legal review if required → Approved / Rejected / More information required → Active within scope → Expired / Revoked / Closed.

Required request fields

Requester; programme; data subject/category; recipient legal entity and named role/contact; recipient country; purpose; exact data categories/fields; minimum necessary dataset; transfer mechanism and lawful basis; consent text/version where relied on; retention/deletion at recipient; onward-transfer rules; security measures; risk assessment; start/end/review date; incident contact; approvers.

Happy path

1) Requester defines purpose and minimum dataset. 2) System validates mandatory fields and identifies sensitive data/cross-border status. 3) Privacy lead reviews lawful basis, transparency, minimisation, recipient safeguards and transfer mechanism. 4) Safeguarding/legal approval is required for welfare data, high-risk recipients, or exceptional sharing. 5) Approver independent from requester authorizes scope and expiry. 6) Data is exported/shared through controlled mechanism; log exact recipient, time, fields and purpose. 7) Expiry/revocation blocks future access and triggers recipient deletion/return confirmation where required.

Baseline controls

Fail closed. Consent is not treated as a universal cure for an otherwise unlawful transfer. No broad standing consent for all future recipients. Approval is specific to recipient, purpose, country and data categories. Any material scope change requires new approval. Public URLs, personal email accounts, and unapproved messaging tools are prohibited for sensitive exports.

Exceptions

Emergency disclosure to protect life requires documented necessity, minimal scope, prompt retrospective review, and audit; it is not a general bypass. Recipient cannot confirm safeguards: reject or reduce scope. Consent withdrawn: stop consent-based future sharing and assess lawful retention/ongoing legal obligations.

Acceptance tests

No export/share without active approved request; destination/recipient/purpose changes invalidate approval; all exports record fields/count/hash where feasible and actor/time; expired approvals block downloads; emergency override requires reason and retrospective review task.

Workflow 8 — CMS, notifications, rights requests and retention

CMS

Content editor drafts; publisher reviews and publishes. Sensitive claims about employment, visas, legal status, safeguarding or donation/tax treatment require designated subject-matter/legal approval. Published content has author, approver, version, timestamp and rollback.

Notifications

Transactional messages use approved templates and minimal content. Sensitive case/profile content is not included. Delivery failures retry with limits and appear in an operational queue. Marketing messages require separate opt-in and easy unsubscribe; unsubscribe must not disable necessary service/security notices.

Data rights

A verified request is logged, identity/authority checked proportionately, scope identified, legal deadline tracked, owner assigned, decision recorded, and response delivered securely. Access/correction/deletion/export actions must not expose another person's data. Legal holds and safeguarding exceptions require reason and approval.

Retention baseline

Provisional only: abandoned unverified registration 90 days after last activity; inactive candidate profile 24 months after last meaningful activity; unsuccessful application 24 months after final decision; successful placement/programme 7 years after closure; welfare case 7 years after closure; donation/accounting records 7 years; consent/sharing evidence duration plus 7 years; audit logs 12 months online; backups 35-day rolling; marketing profile until withdrawal or 24 months inactivity. Privacy/legal owner must validate by jurisdiction and record class before launch.

Deletion

Deletion workflow identifies related copies, storage objects, search indexes, queued exports and downstream systems. Apply legal hold before deletion where valid. Where direct deletion is not appropriate, restrict access and anonymise where lawful. Backup copies expire by schedule; do not claim immediate backup erasure unless implemented.

Task 1 — Identity, RBAC, scope and audit

Build

Authentication, verified email, invitation-only staff accounts, MFA for staff, role and permission registry, programme/partner/country scopes, policy enforcement, session controls, account suspension, password reset, sensitive audit events, and break-glass workflow.

Dependencies

Role specification v1; approved staff MFA approach; named emergency/break-glass recipients before production.

Acceptance gate

Matrix-driven feature tests prove default-deny; cross-tenant and cross-programme denial; staff MFA enforced; role/scope changes audited; break-glass time-limited, reason-required and reviewed; disabled users lose access and active sessions.

Task 2 — Public website, CMS and content governance

Build

Public pages, programmes, opportunity discovery, accessibility baseline, versioned CMS drafts/review/publish/rollback, contact routes, privacy notice and safeguarding information pages.

Dependencies

Approved brand/content; legal-reviewed privacy, donation and safeguarding wording before production publication.

Acceptance gate

Draft is never public; publisher separation works; versions and rollback work; sensitive claims require configured approval; accessibility smoke test passes; no private record is rendered into public search.

Task 3 — Candidate, employer, vacancy and recruitment

Build

Candidate profile, consent ledger, private document upload, programme-scoped review, employer/representative onboarding, verification checklist, vacancy lifecycle, application pipeline, candidate withdrawal, interview/offer records and complaint referral.

Dependencies

Employer evidence checklist and age/minor policy confirmation; vacancy terms and candidate-fee policy.

Acceptance gate

Only approved employers publish; candidate application data is shared only for specific vacancy and recipient; partner scope isolation passes; document access is authorized; state transition and exception tests pass.

Task 4 — Placement management and follow-up

Build

Match record, offer validation, country-specific readiness checklist, placement state machine, document/consent gates, follow-up schedule, at-risk status, closure and outcome reporting.

Dependencies

Destination-country checklist templates; accountable owner for immigration/legal review; no automated visa/legal advice.

Acceptance gate

Cannot activate with mandatory gates missing; changed country/recipient triggers re-review; follow-up tasks are created; employer cannot view welfare case details.

Task 5 — Welfare and safeguarding

Build

Anonymous and authenticated intake, one-time follow-up credential, triage, severity, assignment/backup, restricted notes, safety actions, referrals, escalation log, follow-up, closure review, and case-access audit.

Dependencies

Named safeguarding lead, primary/backup rota, published staffed hours, referral directory, escalation contact validation, approved response targets.

Acceptance gate

Anonymous workflow and credential hash-only verified; P1/P2 escalation tested against configured contacts; no 24/7 claim unless coverage exists; conflicts block access; notifications contain no sensitive details.

Task 6 — Privacy, consent, retention and international sharing

Build

Versioned notices/consents, purpose-bound consent ledger, data-subject request workflow, retention policies/jobs, legal holds, deletion/anonymisation, data-sharing request/approval, transfer register, expiry/revocation, export audit and recipient confirmations.

Dependencies

Legal/privacy approval of lawful bases, transfer mechanisms, retention schedule, rights-response procedure, and ODPC applicability/registration determination.

Acceptance gate

Sharing fails closed; scope change invalidates approval; expired consent/approval blocks relevant future processing; legal holds prevent scheduled deletion; deletion job is idempotent and produces evidence.

Task 7 — Donations, payments and finance

Build

One-time donation intent, hosted checkout adapter, verified provider callbacks, idempotency, receipts, refund workflow, settlement reconciliation, exception queue and finance reporting.

Dependencies

Selected provider, signed merchant terms, finance-approved receipt/tax wording, refund authority/threshold, settlement account and test credentials.

Acceptance gate

No raw card data; spoofed/replayed callback tests fail safely; amount/currency mismatch is quarantined; receipt requires confirmed payment; refunds require separate approval; recurring donations disabled by default.

Task 8 — Notifications, reporting, hardening and release

Build

Email/SMS adapter abstraction, template governance, delivery retry/failure queue, operational alerts, dashboards, approved aggregate reports, export controls, backup/restore procedures, monitoring, security review, staging-to-production deployment and incident runbook.

Dependencies

Selected messaging provider; actual VPS inventory; backup destination/keys; named incident contacts; restore-test window.

Acceptance gate

Sensitive data absent from messages/logs; queue failures visible; reports enforce scope; offsite encrypted backup restored successfully; production secrets excluded from repository; migration/rollback plan rehearsed; security and accessibility gates passed.

Implementation order and release gates

Order

Task 1 foundation → Task 2 public/CMS → Task 3 recruitment → Task 4 placement → Task 5 welfare → Task 6 privacy/sharing → Task 7 donations → Task 8 hardening/release. Some design/test work may run in parallel, but dependencies and gates remain enforced.

Environment

Separate local, staging and production configurations. Use environment variables/secret manager, least-privilege DB accounts, HTTPS, secure cookies, CSRF protection, rate limits, backup encryption, log redaction, dependency review, and restricted admin access.

Release gates

G1 requirements sign-off; G2 identity/security test gate; G3 workflow/UAT gate; G4 privacy/safeguarding/payment gate; G5 backup restore and incident readiness; G6 production go/no-go by accountable human owners.

Definition of done

Code reviewed; migrations reproducible; automated tests green; negative authorization tests green; no known critical/high security defects; logs redacted; documentation updated; staging UAT signed; backup restore proven; rollback plan rehearsed; configuration and owners recorded.

Open decision register — only genuine human/external blockers

OD-01 Safeguarding operations — CONFIRM BEFORE LAUNCH

Name safeguarding lead and backup; approve staffed hours, rota, emergency contacts, referral pathways and whether any out-of-hours coverage truly exists. Until then, response targets are internal proposals and must not be advertised as guarantees.

OD-02 Legal/privacy — CONFIRM BEFORE LAUNCH

Privacy/legal owner validates Kenya and relevant destination-country obligations, lawful bases, international transfer mechanisms, privacy notices, retention schedule, data-subject request procedure, and ODPC registration/applicability.

OD-03 Minors — CONFIRM BEFORE LAUNCH

Baseline: do not enable under-18 international recruitment. Confirm whether any GSK programme serves minors; if yes, approve child safeguarding, consent/assent, guardian and staff-vetting design before onboarding them.

OD-04 Employer verification — CONFIRM BEFORE LAUNCH

Approve accepted registry sources, alternative evidence, re-verification interval, and escalation rules for foreign employers/recruiters.

OD-05 Finance — CONFIRM BEFORE LAUNCH

Select payment provider and settlement account; approve receipt/tax language, refund authority, KES 20,000 provisional threshold, reconciliation owner, and accounting retention.

OD-06 Hosting — CONFIRM BEFORE LAUNCH

Provide actual VPS specs, OS/PHP/database versions, SSH/process manager/scheduler capability, backup destination, DNS/TLS ownership, monitoring contact and recovery objectives. 4 vCPU/8 GB/100 GB is planning only, not verified.

OD-07 Partner agreements — CONFIRM BEFORE PARTNER ACCESS

Define partner types, contract/data-processing roles, programmes/countries, staff roster, permitted data and subprocessors, training, incident reporting, offboarding and audit rights.

OD-08 Named role owners — CONFIRM BEFORE PRODUCTION

Map each role to named individuals and backups; ensure no person can approve their own high-risk request, employer verification, or refund.

OD-09 Providers — CONFIRM BEFORE INTEGRATION

Contract and test email/SMS/payment providers, DPAs, sender domains, webhook signatures, rate limits, regional processing, and support escalation. No provider is treated as selected merely because it is recommended.

OD-10 Acceptance/UAT — CONFIRM BEFORE RELEASE

Name business owner(s) who sign off each workflow, test candidate/employer journeys, accessibility, security, financial reconciliation, safeguarding exercises and restore test.

AI developer operating instructions

Mandatory

Do not skip ahead, collapse tasks, invent policy, weaken acceptance gates, create global admin shortcuts, expose real data in fixtures, or treat UI controls as security. Ask only when an unresolved item blocks safe implementation; otherwise implement the baseline and record assumptions.

Deliver each task

Provide: changed-file list; migrations; route/policy map; tests run and exact result; security considerations; config/env additions; manual verification steps; known gaps; open decisions; rollback notes. Never claim tests ran unless they actually ran.

Stop conditions

Stop and request a decision if a change would enable unapproved cross-border disclosure, under-18 international recruitment, unverified employer publishing, payment capture without verified callbacks, welfare access beyond need-to-know, retention contrary to a legal hold, or production release without required operational owners.

Initial developer instruction

Start with Task 1 only. Inspect the existing scaffold, compare it with this baseline, report gaps before modifying code, implement a small vertical slice, add positive and negative tests, and wait for review at the Task 1 gate before progressing to Task 2.